

PharmaOne AI – API & Backend Requirements (Updated)

FastAPI, Supabase Auth, AI/RAG pipeline, security and reliability.

1. Architecture

React/Redux → FastAPI → Supabase PostgreSQL + Storage → LangGraph/Groq AI services. Use Docker locally and Vercel/Render/Supabase deployment.

2. Authentication

Use Supabase Auth for email/password, session, logout and password reset. FastAPI validates authenticated identity. One login page for Admin and users.

3. Admin APIs

Provide Admin-only operations for listing/creating demo users, activating/deactivating users and reading audit events. Backend verifies Admin role.

4. Deviation APIs

Endpoint	Purpose
POST /deviations/process	Process uploaded/text deviation and return structured extraction + AI assessment.
POST /deviations	Create final reviewed deviation.
GET /deviations	List authorized deviations.
GET /deviations/{id}	Get a deviation.
PUT /deviations/{id}	Update reviewed deviation.
GET /reports/...	Return report data.

5. AI Pipeline

PDF/text → direct text extraction; OCR only when usable text is unavailable → structured extraction → Pydantic validation → query embedding → vector retrieval → deterministic checks → risk assessment/explanation → human review → save.

Reference documents are embedded once during ingestion. Runtime requests create a query embedding and retrieve relevant chunks.

6. Output Contract

Extraction returns structured JSON validated by Pydantic. Risk output contains recommended impact, severity, reason, evidence and retrieved sources. Human review is required before final save.

7. Security

Never trust user_id, role or company_id supplied by frontend. Derive identity from Supabase token, then verify active membership. Return 401 for unauthenticated and 403 for unauthorized requests. Use RLS appropriately.

8. Reliability

Log request_id, endpoint, status, duration and errors. Record AI stage timings. Handle Groq timeouts/rate limits/model errors, malformed JSON, PDF errors and database failures without saving fabricated AI results.